

Evolution of Exposure to Software Security Vulnerabilities (2021-2026)

CVE Data Analysis (NVD) · Final Project — Adalab

Objective

This project analyzes the evolution and characteristics of security vulnerabilities (CVEs) published between 2021 and 2026, based on official data from the National Vulnerability Database (NVD) maintained by NIST. The objective is to answer a central question: are we genuinely more exposed to security risks today than a few years ago, or is the increase in the volume of published vulnerabilities largely the result of better auditing and detection capabilities? To answer this, the analysis studies the evolution over time of vulnerability volume and severity, the most frequent flaw types, the most affected vendors, and the actual exploitability of the reported flaws.

Key insights

1. Growth is concentrated in medium and high severity, not in total volume

MEDIUM severity vulnerabilities show the sharpest growth since 2023, while HIGH severity ones maintain a sustained upward trend throughout the period. The CRITICAL and LOW categories remain comparatively stable. This suggests that the increase is not simply publication 'noise', but is concentrated in vulnerabilities with real consequences.

2. Classic web flaws still dominate

CWE-79 (Cross-Site Scripting) is by far the most frequently reported flaw type. This is a flaw that lets an attacker inject malicious code into a web page so it runs in other users' browsers without them noticing. It is followed by CWE-89 (SQL Injection), which allows database queries to be manipulated in order to steal or alter data, and CWE-862 (Missing Authorization), which occurs when an application fails to properly check whether a user has permission to access a resource. This indicates that a large share of the growth in vulnerabilities comes from web applications, a type of software whose public exposure surface has grown notably in recent years.

3. Nearly three-quarters are remotely exploitable

72.89% of the analyzed vulnerabilities have a NETWORK attack vector, meaning they can be exploited without any physical or local access to the device. This is a key finding for the project's central question: regardless of whether more vulnerabilities are published due to better auditing, most of them represent a real, remotely accessible risk.

4. Exposure is concentrated in a small number of vendors

Microsoft, Qualcomm and Linux account for the largest share of reported vulnerabilities, followed by Apple, Google and Intel. This concentration reflects both the enormous usage share of these products and the greater scrutiny (audits, bug bounty programs) that the largest vendors are subject to.

5. Most flaws are not low severity

The distribution of CVSS scores is concentrated mostly between 5 and 9.5, with only 10.92% of CVEs classified as CRITICAL. In other words, the problem is not a handful of extreme cases, but a large volume of medium-to-high severity vulnerabilities that, together, represent a constant risk burden.

Recommendations

- **Prioritize patching remotely exploitable vulnerabilities.** Since nearly 3 out of 4 vulnerabilities require neither physical nor local access, security teams should treat the NETWORK vector as a top triage criterion, ahead of the total volume of advisories.
- **Strengthen security in web application development.** Given the dominant weight of CWE-79 (XSS) and CWE-89 (SQL Injection) among the most frequent flaw types, it is recommended to invest in code review and automated testing specifically targeting these vulnerability families in any web development project.
- **Prioritize monitoring of the vendors that concentrate the most risk.** Closely tracking the security bulletins of Microsoft, Qualcomm, Linux, Apple and Google, which concentrate most vulnerabilities, offers a much more favorable cost/benefit ratio than trying to cover the entire vendor ecosystem equally.
- **Interpret the growth with nuance, not as a single cause.** The data does not allow us to conclusively separate how much of the increase is due to a real rise in risk versus better detection and publication capabilities. It is recommended to complement this analysis with real incident data (not just published vulnerabilities) for a more complete conclusion.

Conclusion

The analysis does not offer a single answer to the initial question: there is evidence that more vulnerabilities are being published over time, partly due to better auditing, but the fact that most are remotely exploitable and of medium-high severity indicates that the real risk perceived by users and organizations has also increased. Both explanations coexist and are not mutually exclusive.

Appendix — Data Dictionary

The table below details the meaning of each column in the dataset, built from the public NVD API (CVE 2.0) and organized into two related tables: `cves` (one row per vulnerability) and `cve_products` (one row per CVE-affected product/vendor combination).

Column	Meaning
<code>cve_id</code>	Unique identifier of the vulnerability (CVE code, e.g. CVE-2024-11990).
<code>published</code>	Official publication date of the CVE.
<code>last_modified</code>	Date of the last update or revision of the record.
<code>vuln_status</code>	Analysis status in NVD (Analyzed, Modified, Deferred, etc.). CVEs with status 'Rejected' were excluded.
<code>description</code>	Technical description of the vulnerability (in English, as provided by NVD).
<code>cvss_version</code>	CVSS standard version used to score the vulnerability (2.0, 3.0 or 3.1).
<code>base_score</code>	Severity score from 0 to 10 (the higher the value, the more severe).
<code>base_severity</code>	Severity category derived from the score: LOW, MEDIUM, HIGH or CRITICAL.
<code>attack_vector</code>	How the vulnerability can be exploited (NETWORK, LOCAL, ADJACENT NETWORK, PHYSICAL).
<code>attack_complexity</code>	Technical difficulty required to exploit the flaw.
<code>privileges_required</code>	Level of privileges the attacker needs before exploiting the flaw (CVSS v3 only).
<code>user_interaction</code>	Whether exploitation requires the victim to perform some action (CVSS v3 only).
<code>confidentiality_impact</code>	Degree of impact on data confidentiality if the flaw is exploited.
<code>integrity_impact</code>	Degree of impact on data integrity.
<code>availability_impact</code>	Degree of impact on system or service availability.
<code>exploitability_score</code>	Sub-score measuring how easy the vulnerability is to exploit.
<code>impact_score</code>	Sub-score measuring the potential damage if exploited.
<code>cwe</code>	Flaw type category according to the CWE catalog (e.g. CWE-79 = Cross-Site Scripting).
<code>cwe_num</code>	Numeric version of cwe, extracted to make sorting and filtering easier.
<code>num_references</code>	Number of external links (advisories, patches, forums) associated with the CVE.
<code>vendor</code>	Vendor of the affected product (<code>cve_products</code> table).
<code>product</code>	Specific product affected by the vulnerability (<code>cve_products</code> table).

